CYBERSECURITY HOME LAB

Triển khai môi trường kiểm thử bảo mật ứng dụng web và giám sát bằng Wazuh

CHƯƠNG 1. TỔNG QUAN DỰ ÁN

1.1. Mục tiêu

Dự án Cybersecurity Home Lab được xây dựng nhằm tạo ra một môi trường thực hành an ninh mạng có khả năng triển khai ứng dụng web, thực hiện các bài kiểm thử bảo mật có kiểm soát và theo dõi các sự kiện phát sinh thông qua hệ thống giám sát an ninh.

Các mục tiêu chính của dự án bao gồm:

- Triển khai một ứng dụng web thực tế trên máy Ubuntu làm mục tiêu kiểm thử.
- Kết nối ứng dụng với hệ quản trị cơ sở dữ liệu MySQL.
- Thiết lập kết nối mạng giữa máy kiểm thử Kali Linux và máy Ubuntu mục tiêu.
- Cấu hình tường lửa nhằm kiểm soát lưu lượng truy cập đến ứng dụng.
- Sử dụng Wazuh để hỗ trợ thu thập, phân tích log và phát hiện các hoạt động đáng ngờ.
- Đánh giá kết quả kiểm thử và đề xuất các biện pháp cải thiện bảo mật.

1.2. Phạm vi thực hiện

Trong giai đoạn đầu, dự án tập trung vào việc chuẩn bị môi trường, triển khai ứng dụng web và kiểm tra khả năng kết nối giữa các máy trong phòng lab.

Ứng dụng Employee Management được sử dụng làm mục tiêu kiểm thử. Các giai đoạn tiếp theo sẽ tập trung vào kiểm thử xác thực, phân quyền, quản lý phiên đăng nhập và khả năng giám sát sự kiện bảo mật.

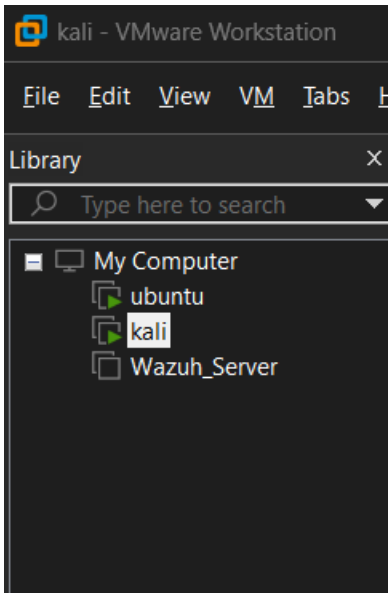
Các hoạt động kiểm thử được thực hiện trong môi trường do người triển khai quản lý và được giới hạn trong phạm vi được cho phép.

CHƯƠNG 2. XÂY DỰNG MÔI TRƯỜNG LAB

2.1. Các thành phần chính

Môi trường Cybersecurity Home Lab được triển khai trên nền tảng ảo hóa VMware Workstation, kết hợp với dịch vụ cơ sở dữ liệu đám mây, bao gồm các thành phần có chức năng riêng biệt:

- **Kali Linux (Attacker / Security Tester):** Máy ảo dùng để thực hiện các bài kiểm thử bảo mật ứng dụng web và kiểm tra dịch vụ mạng.
- **Ubuntu Target (Application Server):** Máy chủ triển khai ứng dụng mục tiêu Employee Management chạy trên môi trường Node.js và được cài đặt Wazuh Agent.
- **Aiven MySQL (Cloud Database):** Dịch vụ cơ sở dữ liệu MySQL từ xa lưu trữ dữ liệu của ứng dụng.
- **Wazuh Server (SIEM / Monitoring):** Máy chủ thu thập, phân tích log từ Ubuntu Agent và hiển thị cảnh báo an ninh mạng.

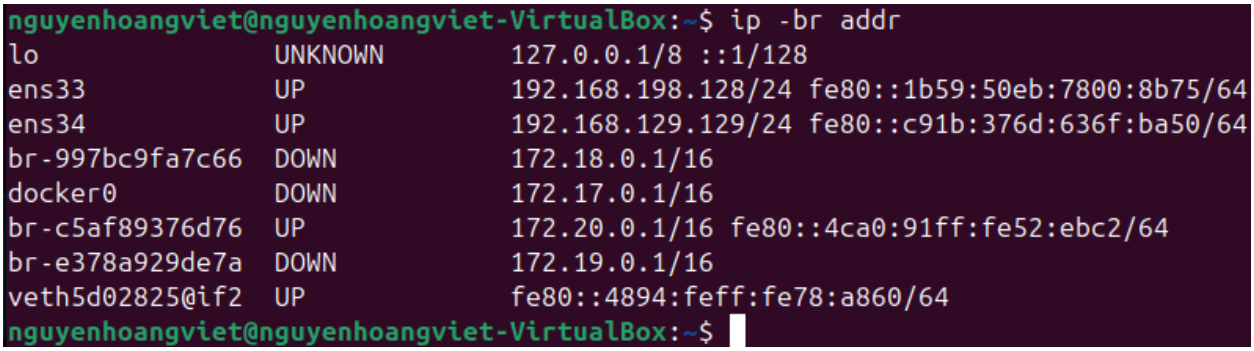


Hình 2.1. Tổng quan môi trường Cybersecurity Home Lab trên VMware

2.2 Cấu hình và địa chỉ mạng

Ubuntu Target sử dụng hai giao diện mạng: giao diện ens33 (192.168.198.128/24) và giao diện ens34 (192.168.129.129/24). Trong đó, giao diện ens34 được sử dụng để giao tiếp trực tiếp với Kali Linux và Wazuh Server trong dải mạng nội bộ của lab là 192.168.129.0/24.

Thành phần	Giao diện	Địa chỉ IP	Vai trò trong mạng Lab
Ubuntu Target	ens33	192.168.198.128/24	Kết nối ra ngoài / Quản trị
Ubuntu Target	ens34	192.168.129.129/24	Mạng Lab nội bộ (chạy Web App cổng 8000)
Wazuh Server	Mạng lab	192.168.129.131	Thu thập log và giám sát SIEM
Kali Linux	Mạng lab	192.168.129.xxx/24 *(điền IP từ ip -br addr)*	Máy thực hiện kiểm thử

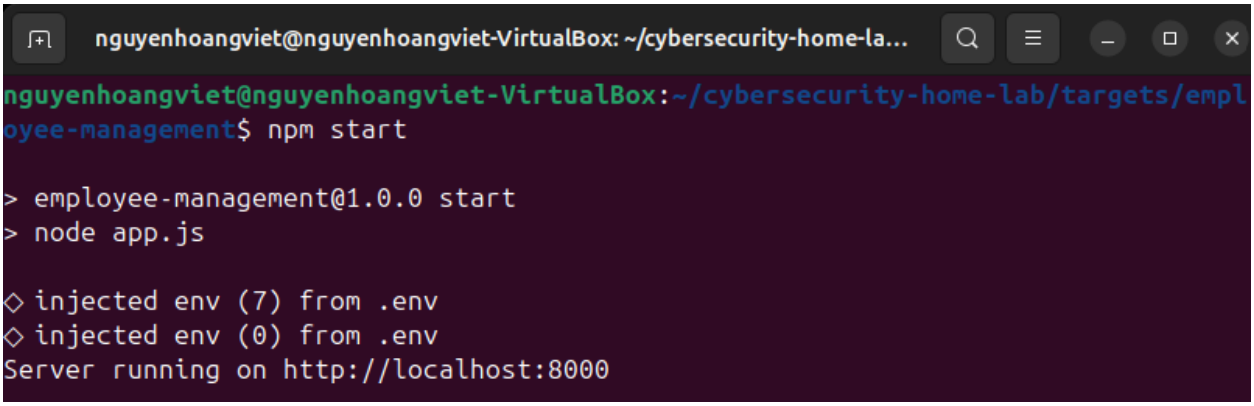


Hình 2.2. Thông tin địa chỉ IP của các giao diện mạng trên Ubuntu Target

Chương 3. TRIỂN KHAI ỨNG DỤNG WEB MỤC TIÊU

3.1. Chuẩn bị mã nguồn

Mã nguồn ứng dụng Employee Management được lưu trữ và triển khai trên Ubuntu Target tại đường dẫn ~/cybersecurity-home-lab/targets/employee-management. Ứng dụng được xây dựng bằng Node.js và Express để xử lý các yêu cầu HTTP, kết hợp với template engine EJS để hiển thị giao diện người dùng. Sau khi cài đặt các thư viện phụ thuộc qua npm, ứng dụng được khởi chạy bằng lệnh npm start (node app.js) và lắng nghe trên cổng TCP 8000

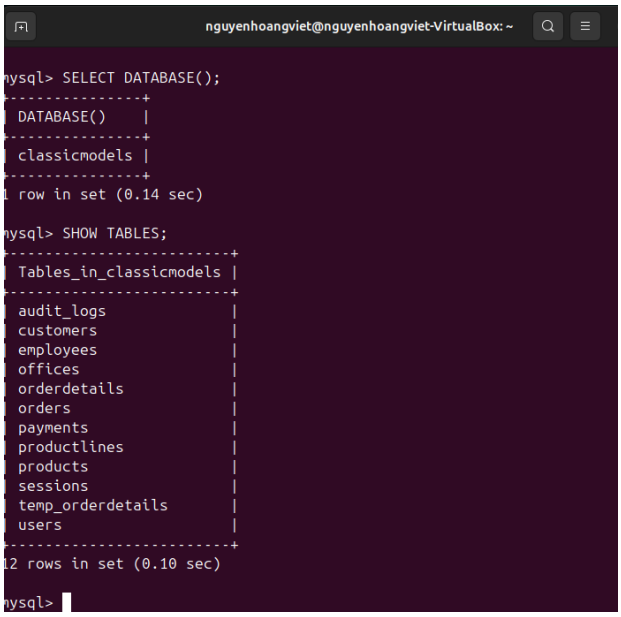


Hình 3.1. Mã nguồn và quá trình khởi chạy ứng dụng Employee Management.

3.2. Cấu hình cơ sở dữ liệu

Ứng dụng kết nối tới hệ quản trị cơ sở dữ liệu Aiven MySQL thông qua thư viện mysql2/promise. Các thông số nhạy cảm (host, port, tài khoản, mật khẩu, tên database classicmodels và cấu hình SSL) được nạp từ file .env. Để đảm bảo an toàn, file .env đã được đưa vào .gitignore nhằm ngăn ngừa lộ lọt thông tin lên GitHub và được giới hạn quyền đọc/ghi trên máy chủ bằng lệnh chmod 600.

Kết nối từ Ubuntu Target đến database classicmodels trên Aiven MySQL đã được xác minh thành công với đầy đủ 12 bảng dữ liệu: audit_logs, customers, employees, offices, orderdetails, orders, payments, productlines, products, sessions, temp_orderdetails, và users.

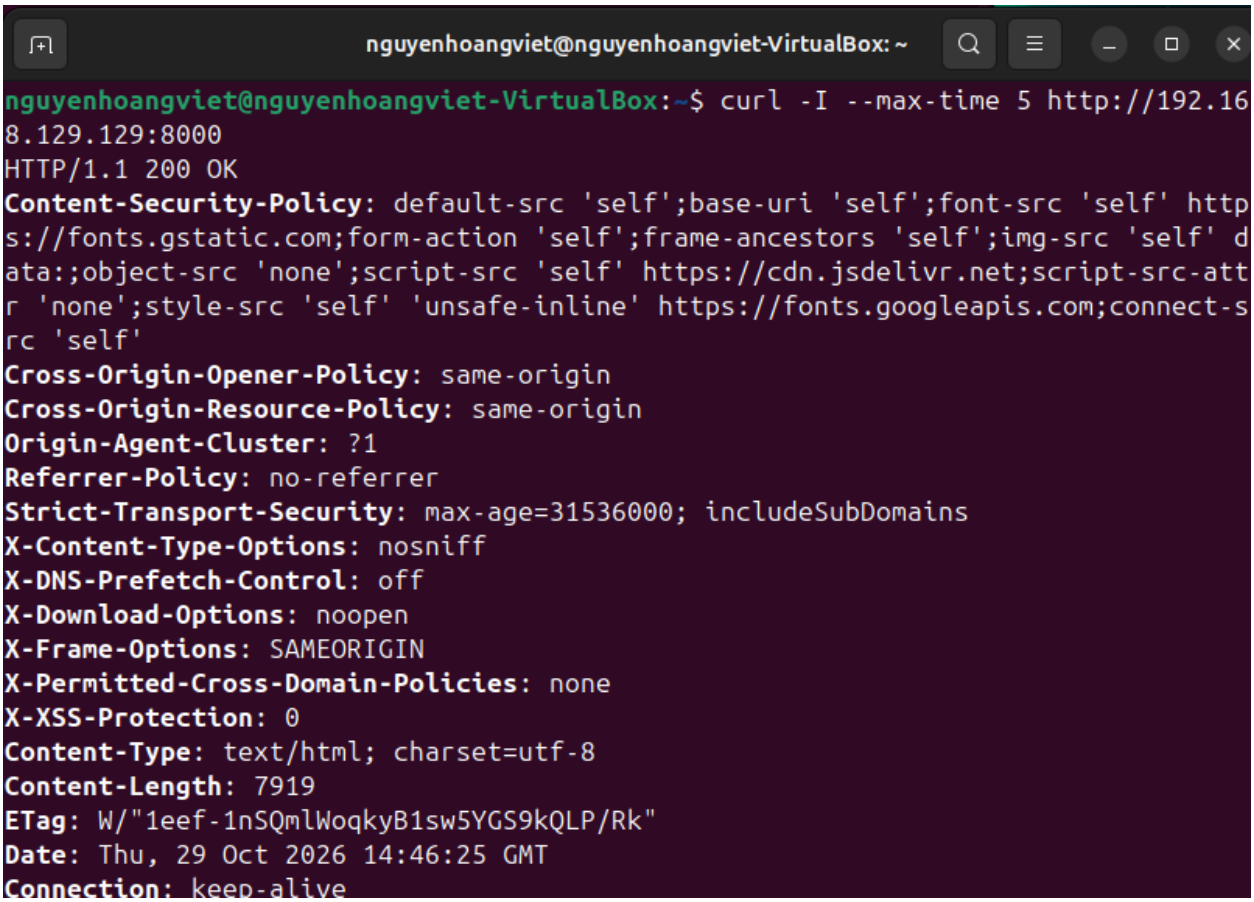


Hình 3.2. Kiểm tra database và các bảng trên Aiven MySQL.

Nguyên tắc an toàn trong kiểm thử: Do database classicmodels trên Aiven đang được dùng chung với môi trường triển khai thực tế, mọi hoạt động kiểm thử trong dự án đều tuân thủ nguyên tắc không gửi các yêu cầu làm tạo mới, chỉnh sửa, xóa dữ liệu hoặc làm nhiễu bảng audit_logs khi chưa có cơ chế cô lập an toàn.

3.3. Kiểm tra phản hồi HTTP nội bộ

Sau khi ứng dụng khởi chạy và tiến trình Node.js được xác nhận đang lắng nghe trên cổng TCP 8000 (qua lệnh ss -lntp), lệnh curl -I --max-time 5 http://192.168.129.129:8000 được thực thi trực tiếp trên Ubuntu Target. Hệ thống phản hồi mã trạng thái HTTP/1.1 200 OK cùng các HTTP Security Headers, xác nhận ứng dụng hoạt động ổn định trên giao diện mạng lab.



Hình 3.3. Kết quả kiểm tra phản hồi HTTP của ứng dụng.

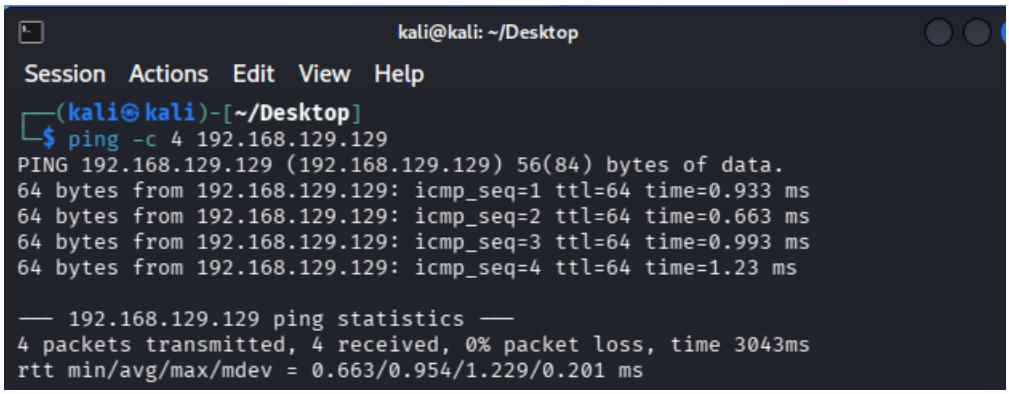
3.4. Cấu hình tường lửa (UFW) và kiểm tra kết nối từ Kali Linux

Trên Ubuntu Target, tường lửa UFW hoạt động với chính sách mặc định chặn các kết nối đến (deny incoming), dẫn đến hiện tượng timeout ở lần đầu truy cập cổng 8000 từ Kali Linux. Để mở quyền truy cập có kiểm soát, một quy tắc UFW được thiết lập chỉ cho phép dải mạng lab 192.168.129.0/24 kết nối tới cổng TCP 8000 thay vì mở toàn bộ địa chỉ nguồn:

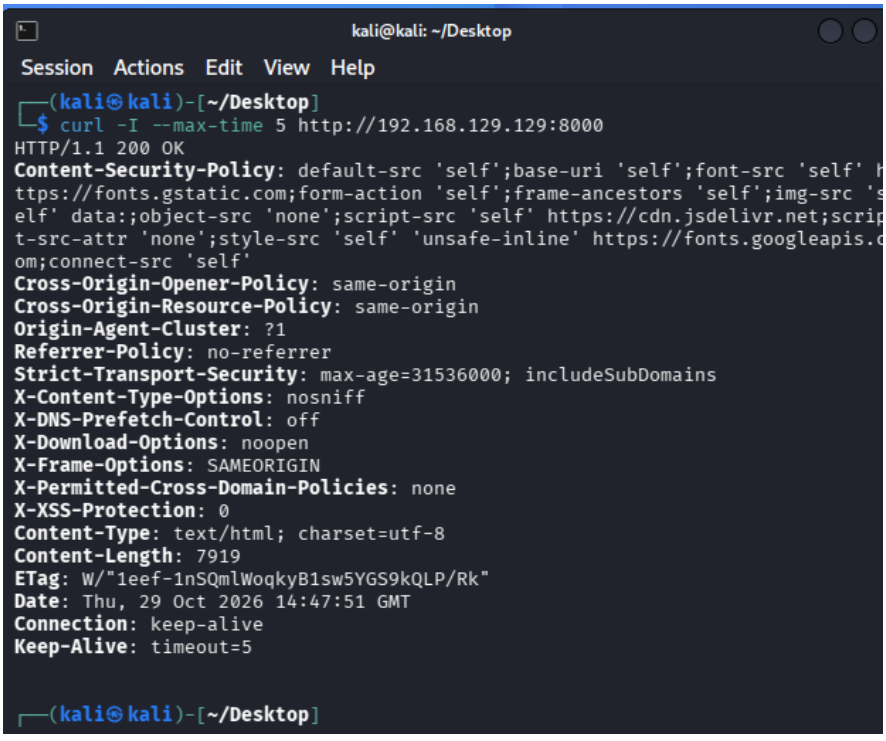
sudo ufw allow from 192.168.129.0/24 to any port 8000 proto tcp

Sau khi cấu hình tường lửa, quá trình kiểm tra kết nối từ Kali Linux tới Ubuntu Target (192.168.129.129) ghi nhận kết quả thành công ở cả tầng mạng và tầng ứng dụng:

1. **Kiểm tra ICMP (ping -c 4 192.168.129.129):** Gửi và nhận thành công 4/4 gói tin, tỷ lệ mất gói 0% (rtt avg = 0.954 ms).
2. **Kiểm tra HTTP (curl -I --max-time 5 http://192.168.129.129:8000):** Nhận phản hồi HTTP/1.1 200 OK từ máy chủ ứng dụng.



Hình 3.5. Kết quả kiểm tra kết nối mạng giữa Kali Linux và Ubuntu Target.



Hình 3.6. Kết quả xác minh truy cập HTTP từ Kali Linux tới ứng dụng mục tiêu.

CHƯƠNG 4. ĐÁNH GIÁ BẢO MẬT ỨNG DỤNG WEB VÀ MÃ NGUỒN

Trong giai đoạn này, dự án thực hiện đánh giá bảo mật ứng dụng Employee Management kết hợp giữa phương pháp phân tích động (Dynamic Analysis - thông qua các HTTP request) và rà soát mã nguồn tĩnh (Static Analysis) đối với các file cấu hình và logic xử lý của Node.js.

4.1. Đánh giá cấu hình HTTP Security Headers

Thông qua phản hồi HTTP tại máy kiểm thử Kali Linux đối với địa chỉ http://192.168.129.129:8000, ứng dụng đã kích hoạt một số cơ chế bảo vệ HTTP Headers (thông qua middleware Helmet), nhưng vẫn còn tồn tại các điểm yếu cấu hình:

- Các cơ chế bảo vệ đang hoạt động hiệu quả:
    - X-Content-Type-Options: nosniff: Đã được cấu hình đúng, giúp ngăn chặn trình duyệt tự động đoán sai kiểu MIME.
    - X-Frame-Options: SAMEORIGIN và frame-ancestors 'self' (trong CSP): Giúp phòng chống tấn công Clickjacking hiệu quả bằng cách ngăn ứng dụng bị nhúng vào các iframe ngoại lai.
    - Referrer-Policy: no-referrer: Hạn chế rò rỉ URL nguồn khi người dùng điều hướng.
- Các điểm yếu cấu hình cần khắc phục:
    - **HSTS không có hiệu lực thực tế:** Mặc dù máy chủ có trả về header Strict-Transport-Security: max-age=31536000; includeSubDomains, nhưng ứng dụng lại đang được phục vụ qua giao thức HTTP thuần không mã hóa. Theo đặc tả RFC 6797, trình duyệt sẽ bỏ qua header này nếu nó không được gửi qua kết nối HTTPS, dẫn đến việc không thể ép buộc kết nối an toàn
    - **Chính sách CSP nới lỏng:** Header Content-Security-Policy đang sử dụng chỉ thị style-src 'self' 'unsafe-inline'. Việc cho phép 'unsafe-inline' có thể tạo điều kiện cho các cuộc tấn công tiêm nhiễm CSS (CSS Injection) nếu kẻ tấn công kiểm soát được đầu vào của trang.

4.2. Rà soát cấu hình kết nối và Quản lý phiên (Session Management)

Qua việc rà soát mã nguồn (các file .env, cấu hình kết nối cơ sở dữ liệu và cấu hình session), hai rủi ro bảo mật cấu hình (Security Misconfiguration) đã được ghi nhận:

- **Xác thực TLS khi kết nối cơ sở dữ liệu:** Cấu hình kết nối đến dịch vụ Aiven MySQL đang sử dụng tham số rejectUnauthorized: false. Thiết lập này buộc ứng dụng bỏ qua việc xác minh tính hợp lệ của chứng chỉ SSL/TLS từ máy chủ cơ sở dữ liệu. Mặc dù dữ liệu vẫn được mã hóa trên đường truyền, ứng dụng có nguy cơ bị tấn công Man-in-the-Middle (MitM) nếu kẻ tấn công chặn bắt và tráo đổi chứng chỉ.

- **Khóa bí mật của Session (Session Secret):** Mã nguồn cấu hình session đang chứa một chuỗi secret dự phòng cố định (hardcoded fallback secret) trong trường hợp biến môi trường không được thiết lập. Nếu ứng dụng được triển khai trên môi trường production mà quản trị viên quên cấu hình biến môi trường này, kẻ tấn công có thể sử dụng chuỗi dự phòng bị lộ trong mã nguồn để giả mạo (forge) session cookie và chiếm quyền tài khoản.

4.3. Rà soát kiểm soát đầu vào (Input Validation) và Xử lý lỗi

Phân tích logic xử lý tại các controller (đặc biệt là employeeController.js) cho thấy một số thiếu sót trong việc kiểm tra tính hợp lệ của dữ liệu đầu vào và kiểm soát thông báo lỗi:

- **Xử lý kiểu dữ liệu số (Type Validation):** Hàm validateNumber() và việc sử dụng parseInt() trong các thao tác cập nhật (Update) và xóa (Delete) chưa đủ chặt chẽ. parseInt() có thể phân tích thành công một chuỗi bắt đầu bằng số (ví dụ: 123abc thành 123), dẫn đến việc dữ liệu rác có thể lọt qua lớp kiểm tra.
- **Lộ lọt thông tin qua thông báo lỗi (Improper Error Handling):** Tại một số nhánh catch, ứng dụng đang trả trực tiếp đối tượng error.message từ hệ thống hoặc cơ sở dữ liệu về cho người dùng cuối. Việc này vi phạm nguyên tắc bảo mật, vì các thông báo lỗi này có thể chứa đường dẫn file cục bộ, cấu trúc bảng cơ sở dữ liệu hoặc các thông tin nhạy cảm khác, hỗ trợ kẻ tấn công trong quá trình trinh sát.

CHƯƠNG 5. GIÁM SÁT AN NINH VÀ PHÁT HIỆN SỰ KIỆN VỚI SIEM WAZUH

Sau khi hoàn tất đánh giá bảo mật trên ứng dụng web, dự án tiến hành kiểm chứng khả năng giám sát và cảnh báo của hệ thống SIEM (Wazuh) đối với các hành vi xâm nhập và leo thang đặc quyền ở tầng hệ điều hành.

5.1. Kịch bản kiểm thử giám sát

Để đánh giá độ nhạy của Wazuh Agent được cài đặt trên Ubuntu Target, một kịch bản tấn công dò đoán mật khẩu và leo thang đặc quyền nội bộ (Local Privilege Escalation) đã được mô phỏng. Trực tiếp trên giao diện dòng lệnh của máy Ubuntu, các thao tác sau đã được thực hiện:

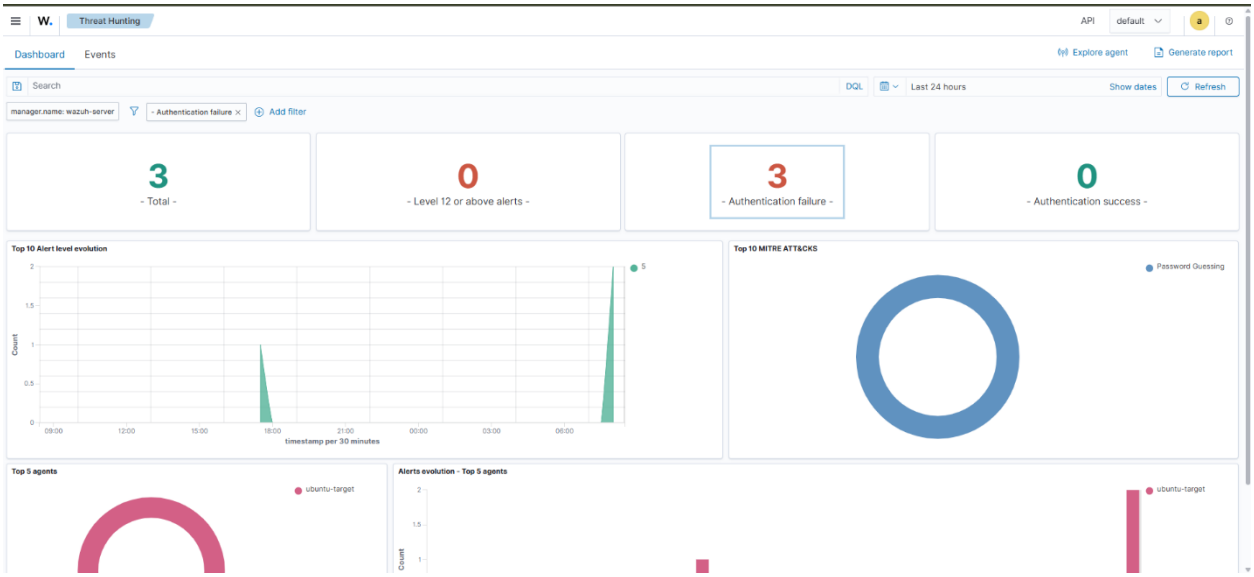
- Cố gắng chuyển đổi sang một tài khoản không tồn tại (su - hacker), tạo ra lỗi xác thực tài khoản hợp lệ.
- Cố gắng chuyển đổi sang tài khoản quản trị (su - root) nhưng cố tình nhập sai mật khẩu nhiều lần nhằm mô phỏng hành vi dò đoán mật khẩu.

Các hành vi này ngay lập tức được hệ điều hành ghi nhận vào tệp nhật ký bảo mật /var/log/auth.log và được Wazuh Agent đẩy về Wazuh Server để phân tích.

5.2. Kết quả ghi nhận và cảnh báo trên Wazuh Dashboard

Qua kiểm tra trên giao diện điều khiển (Dashboard) của Wazuh Server thuộc phân hệ Threat Hunting, hệ thống đã phát hiện và phân loại thành công các nỗ lực xâm nhập:

- **Số lượng cảnh báo:** Bảng điều khiển ghi nhận tổng cộng 3 sự kiện cảnh báo "Authentication failure" (Đăng nhập thất bại) xuất hiện trong khung thời gian 24 giờ qua.
- **Định danh nguồn phát sinh:** Toàn bộ 3 cảnh báo này đều được định danh chính xác nguồn gốc xuất phát từ agent có tên ubuntu-target (đại diện cho máy chủ chạy ứng dụng web).
- **Phân loại theo MITRE ATT&CK:** Đáng chú ý, module phân tích của Wazuh đã tự động ánh xạ các nỗ lực đăng nhập sai này vào cơ sở dữ liệu MITRE ATT&CK, xếp loại hành vi này thuộc kỹ thuật **"Password Guessing"** (Dò đoán mật khẩu).



Hình 5.1. Bảng điều khiển Wazuh hiển thị các cảnh báo Authentication failure và phân loại Password Guessing

5.3. Đánh giá năng lực phát hiện của hệ thống

Từ kết quả kiểm thử trên, có thể rút ra các kết luận sau về môi trường Security Home Lab:

1. **Luồng dữ liệu thông suốt:** Kết nối giữa Ubuntu Target (Agent) và Wazuh Server hoạt động ổn định. Agent thu thập log theo thời gian thực và đẩy về Server phân tích mà không gặp độ trễ đáng kể.

2. **Khả năng phân tích ngữ cảnh:** Wazuh không chỉ thu thập log thô mà còn áp dụng thành công các bộ quy tắc (ruleset) để phát hiện sự bất thường (đăng nhập sai liên tục) và gán nhãn mối đe dọa chuẩn quốc tế (MITRE ATT&CK).
3. **Giá trị thực tiễn (Blue Team):** Cấu hình này cung cấp tầm nhìn toàn diện cho người quản trị mạng. Nếu một kẻ tấn công lợi dụng điểm yếu ứng dụng web để thực thi mã từ xa (RCE) và cố gắng leo thang đặc quyền bên trong máy chủ Ubuntu, hệ thống SIEM sẽ ngay lập tức phát đi báo động.

CHƯƠNG 6. TỔNG KẾT VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết quả đạt được

Dự án "Cybersecurity Home Lab" đã hoàn thành các mục tiêu cốt lõi đề ra từ đầu, tạo ra một môi trường khép kín và an toàn để thực hành các kỹ năng An toàn thông tin:

- Triển khai thành công ứng dụng web Node.js dễ bị tổn thương có kiểm soát trên môi trường Ubuntu và kết nối dữ liệu tới dịch vụ đám mây Aiven MySQL.
- Cấu hình an toàn mạng cơ bản với tường lửa UFW, đảm bảo giới hạn quyền truy cập dịch vụ trong khuôn khổ mạng Lab (192.168.129.0/24).
- Thực hiện đánh giá mã nguồn tĩnh và truy vấn HTTP, phát hiện ra các điểm yếu thực tế liên quan đến quản lý phiên (Session), cấu hình HTTP Security Headers và xác thực đầu vào.
- Tích hợp thành công và chứng minh được năng lực giám sát, phát hiện cảnh báo rủi ro bảo mật (Password Guessing) theo chuẩn MITRE ATT&CK của hệ thống SIEM Wazuh.

6.2. Hướng phát triển trong tương lai

Trong các giai đoạn mở rộng tiếp theo, dự án có thể triển khai thêm các hạng mục:

1. **Khắc phục lỗ hổng (Remediation):** Cập nhật mã nguồn ứng dụng để vá các điểm yếu đã phát hiện (áp dụng Regex cho kiểm tra đầu vào, cấu hình lại chứng chỉ SSL cho MySQL, xử lý thông báo lỗi an toàn).
2. **Cấu hình Rule tùy chỉnh trên Wazuh:** Viết các bộ rule giám sát chuyên sâu để phát hiện các cuộc tấn công đặc thù vào Web như SQL Injection hay XSS dựa trên log của Web Server (Nginx/Apache).
3. **Triển khai tự động hóa:** Đóng gói toàn bộ phòng lab bằng Docker Compose hoặc Vagrant để dễ dàng tái tạo môi trường chỉ với một câu lệnh.